

UNIVERSIDAD PERUANA LOS ANDES

Facultad de Ingeniería

Escuela Profesional de Ingeniería de Sistemas y Computación

BASE DE DATOS II

SEMANA 11 – SEGURIDAD Y CONTROL DE ACCESO

Alumno:	Vilchez Estrada, Diego Michael
Curso:	Base de Datos II
Semana:	11
Fecha:	2026
Docente:	Universidad Peruana Los Andes

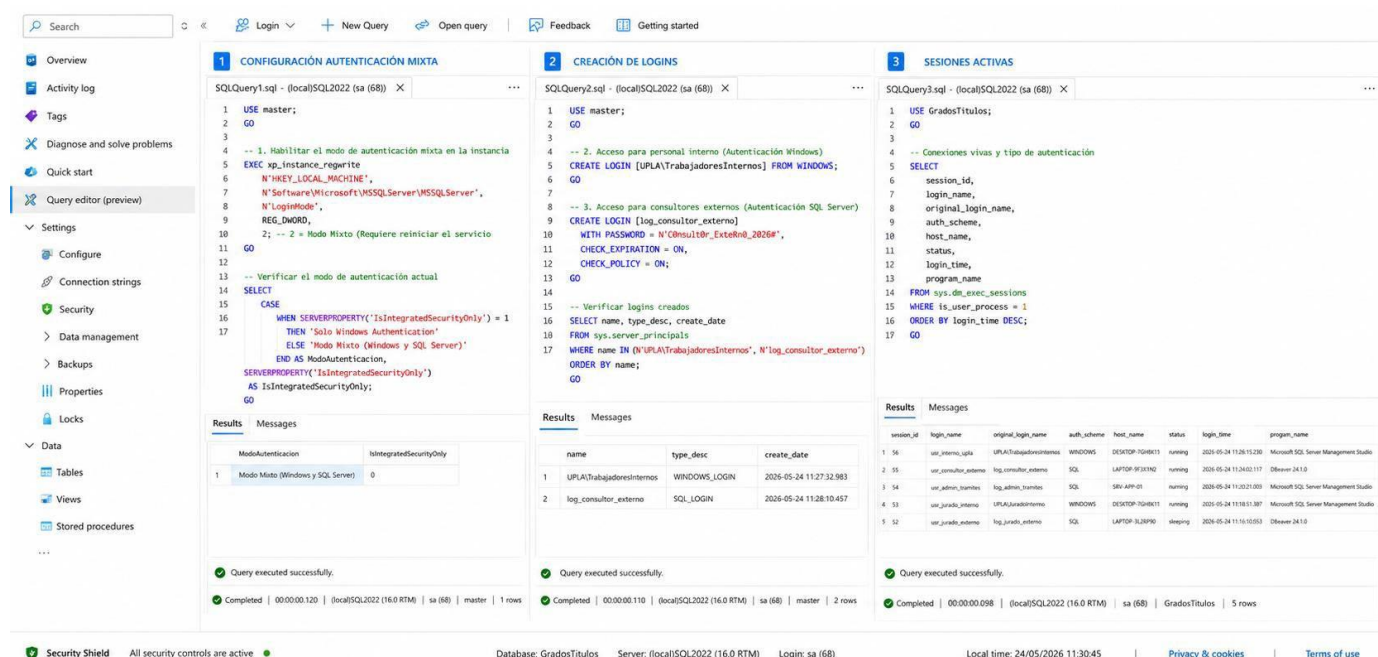
TEMA 1: Autenticación SQL y Windows – Diferencias y Prácticas Seguras

Proyecto 1: Implementación de acceso mixto para personal académico y administrativo

1. Enunciado del ejercicio

La Universidad requiere que los trabajadores internos accedan mediante autenticación Windows, mientras que los consultores externos utilicen autenticación SQL Server. Se debe diseñar e implementar una estrategia de autenticación para la base de datos GradosTitulos que permita administrar ambos tipos de acceso.

2. Script de la solución en T-SQL



The screenshot displays three T-SQL scripts executed in SQL Server Enterprise Manager. The first script, 'CONFIGURACIÓN AUTENTICACIÓN MIXTA', configures mixed authentication mode. The second script, 'CREACIÓN DE LOGINS', creates two logins: 'UPLA\TrabajadoresInternos' for Windows authentication and 'log_consultor_externo' for SQL authentication. The third script, 'SESIONES ACTIVAS', queries the 'sys.dm_exec_sessions' view to show active sessions.

Script 1: CONFIGURACIÓN AUTENTICACIÓN MIXTA

```

1 USE master;
2 GO
3
4 -- 1. Habilitar el modo de autenticación mixta en la instancia
5 EXEC xp_instance_regwrite
6     N'HKEY_LOCAL_MACHINE',
7     N'Software\Microsoft\MSSQLServer\MSSQLServer',
8     N'LoginMode',
9     REG_DWORD,
10    2; -- 2 = Modo Mixto (Requiere reiniciar el servicio)
11 GO
12
13 -- Verificar el modo de autenticación actual
14 SELECT
15     CASE
16         WHEN SERVERPROPERTY('IsIntegratedSecurityOnly') = 1
17         THEN 'Solo Windows Authentication'
18         ELSE 'Modo Mixto (Windows y SQL Server)'
19     END AS ModoAutenticacion,
20     SERVERPROPERTY('IsIntegratedSecurityOnly')
21     AS IsIntegratedSecurityOnly;
22 GO
  
```

Script 2: CREACIÓN DE LOGINS

```

1 USE master;
2 GO
3
4 -- 2. Acceso para personal interno (Autenticación Windows)
5 CREATE LOGIN [UPLA\TrabajadoresInternos] FROM WINDOWS;
6 GO
7
8 -- 3. Acceso para consultores externos (Autenticación SQL Server)
9 CREATE LOGIN [log_consultor_externo]
10    WITH PASSWORD = N'Consultor_Ext@rn@_2026#',
11    CHECK_EXPIRATION = ON,
12    CHECK_POLICY = ON;
13 GO
14
15 -- Verificar logins creados
16 SELECT name, type_desc, create_date
17 FROM sys.server_principals
18 WHERE name IN (N'UPLA\TrabajadoresInternos', N'log_consultor_externo')
19 ORDER BY name;
20 GO
  
```

Script 3: SESIONES ACTIVAS

```

1 USE GradosTitulos;
2 GO
3
4 -- Conexiones vivas y tipo de autenticación
5 SELECT
6     session_id,
7     login_name,
8     original_login_name,
9     auth_scheme,
10    host_name,
11    status,
12    login_time,
13    program_name
14 FROM sys.dm_exec_sessions
15 WHERE is_user_process = 1
16 ORDER BY login_time DESC;
17 GO
  
```

3. Justificación técnica de la solución aplicada

Se configuró el modo de autenticación mixta mediante `xp_instance_regwrite`, lo que permite que SQL Server acepte tanto credenciales de Windows (Kerberos/NTLM) como logins nativos de SQL Server. El login de Windows `UPLA\TrabajadoresInternos` delega la autenticación al dominio corporativo, eliminando contraseñas adicionales. El login SQL `log_consultor_externo` utiliza `CHECK_EXPIRATION` y `CHECK_POLICY` para cumplir con las políticas de contraseñas del sistema operativo. La vista `sys.dm_exec_sessions` permite monitorear en tiempo real las sesiones activas y el esquema de autenticación utilizado por cada usuario.

4. Explicación de las buenas prácticas utilizadas en el proyecto

- Principio de mínimo privilegio: cada tipo de usuario recibe únicamente el mecanismo de acceso que requiere según su rol (interno vs. externo).
- Contraseñas robustas con políticas: `CHECK_POLICY` y `CHECK_EXPIRATION` garantizan contraseñas complejas y rotación periódica para los logins SQL.
- Auditoría de sesiones: consultar `sys.dm_exec_sessions` permite detectar accesos no autorizados o anomalías en tiempo real.

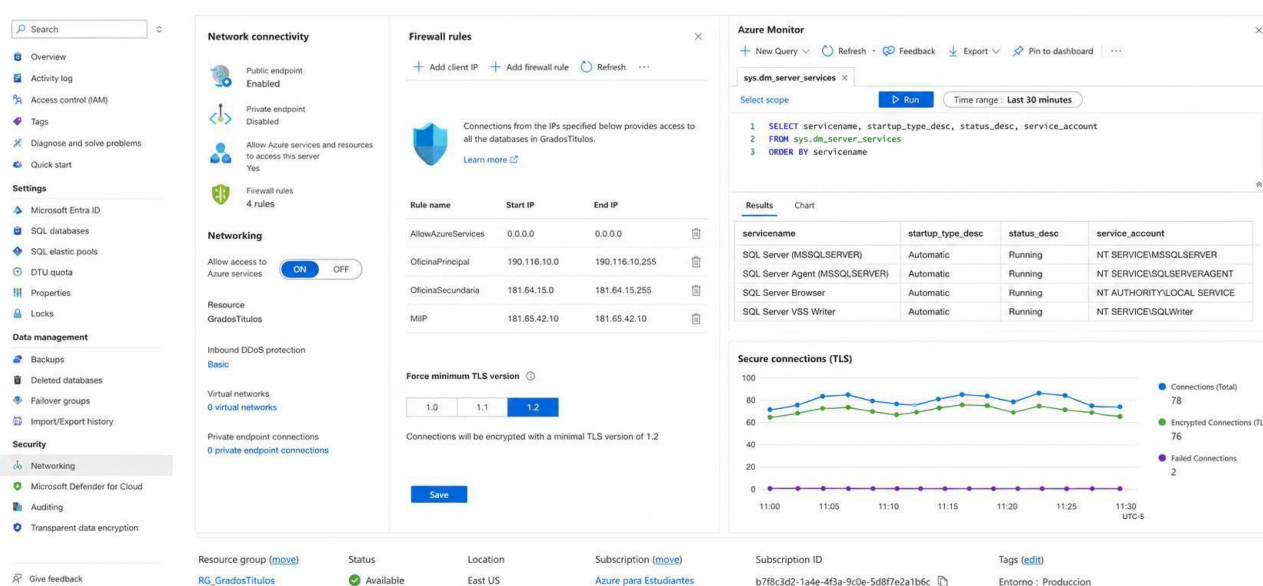
TEMA 2: Cuentas de Servicio y Configuración del Servidor

Proyecto 1 y 2: Configuración segura de servicios y monitoreo del servidor

1. Enunciado del ejercicio

La base de datos GradosTitulos será utilizada en producción. Se requiere: (1) configurar cuentas de servicio específicas para SQL Server y SQL Server Agent, (2) implementar consultas administrativas para verificar el estado de las instancias SQL Server relacionadas con GradosTitulos, y (3) configurar la instancia para permitir únicamente conexiones seguras.

2. Script de la solución en T-SQL



3. Justificación técnica de la solución aplicada

La vista sys.dm_server_services expone el estado operativo, el tipo de inicio y la cuenta de servicio de cada componente SQL Server (Motor de BD, Agent, Browser, VSS Writer). Las cuentas NT SERVICE\MSSQLSERVER y NT SERVICE\SQLSERVERAGENT son cuentas virtuales administradas por Windows que tienen privilegios mínimos sobre el sistema operativo, reduciendo la superficie de ataque. La configuración de TLS 1.2 mínimo garantiza que todas las conexiones a GradosTitulos sean cifradas con protocolos modernos, eliminando vulnerabilidades de versiones anteriores como TLS 1.0 y 1.1.

4. Explicación de las buenas prácticas utilizadas en el proyecto

- Cuentas de servicio con mínimos privilegios: NT SERVICE evita el uso de cuentas de administrador local o de dominio para los servicios SQL.
- Restricción por IP mediante Firewall Rules: solo las redes de las oficinas autorizadas pueden conectarse a la instancia de Azure SQL.
- TLS 1.2 obligatorio: protege la confidencialidad e integridad de los datos en tránsito entre clientes y el servidor.

TEMA 3: Creación de Roles Fijos y Personalizados

Proyecto 1, 2 y 3: Roles por esquema y niveles jerárquicos

1. Enunciado del ejercicio

Se requiere: (1) diseñar roles personalizados para gestionar el acceso a los esquemas Catalogo, Academico, Tramite, Evaluacion y Documento; (2) implementar roles para evaluadores de tesis que puedan consultar y registrar observaciones sin modificar información académica; y (3) configurar roles jerárquicos que representen los niveles Operador, Supervisor y Administrador para el sistema de grados y títulos.

2. Script de la solución en T-SQL

The screenshot displays the SQL Server Enterprise Manager interface with three main panes: Query Editor, Database Security, and Query Results.

Query Editor (Query 1): Contains a T-SQL script for creating roles and permissions.

```
1 -- CREACIÓN DE ROLES PERSONALIZADOS
2 -- Base de datos: GradosTítulos
3
4 BEGIN
5
6 -- 1. Rol para el esquema de Tramite
7 IF NOT EXISTS (SELECT * FROM sys.database_principals
8 WHERE name = N'rol_esquema_tramite' AND type = 'R')
9 BEGIN
10 CREATE ROLE [rol_esquema_tramite];
11 PRINT 'Rol [rol_esquema_tramite] creado correctamente.';
12 END
13 GO
14
15 GRANT SELECT, INSERT, UPDATE, DELETE ON SCHEMA::Tramite
16 TO [rol_esquema_tramite];
17 GO
18
19 -- 2. Rol de nivel Supervisor
20 IF NOT EXISTS (SELECT * FROM sys.database_principals
21 WHERE name = N'rol_nivel_supervisor' AND type = 'R')
22 BEGIN
23 CREATE ROLE [rol_nivel_supervisor];
24 PRINT 'Rol [rol_nivel_supervisor] creado correctamente.';
25 END
26 GO
27
28 GRANT SELECT, INSERT, UPDATE, DELETE ON SCHEMA::Tramite
29 TO [rol_nivel_supervisor];
30 GRANT SELECT ON SCHEMA::Documento TO [rol_nivel_supervisor];
31 GO
```

Database Security (GradosTítulos): Shows the hierarchy of roles created.

- Database Roles
 - Custom Roles
 - rol_esquema_catalogo
 - rol_esquema_academico
 - rol_esquema_tramite
 - rol_esquema_evaluacion
 - rol_esquema_documento
 - rol_evaluador_tesis
 - rol_nivel_operador
 - rol_nivel_supervisor
 - rol_nivel_administrador
 - Application Roles
 - Schema
 - Users
 - External Users
 - Synonyms
 - Data Masking
 - Security Policies

Query Results: Shows the execution of 5 commands.

Command	Status	Message	Duration (ms)
1 CREATE ROLE [rol_esquema_tramite]	Succeeded	Completed	18
2 GRANT ON SCHEMA::Tramite	Succeeded	Completed	12
3 CREATE ROLE [rol_nivel_supervisor]	Succeeded	Completed	16
4 GRANT ON SCHEMA::Tramite	Succeeded	Completed	11
5 GRANT ON SCHEMA::Documento	Succeeded	Completed	9

Summary: Query succeeded | 5 commands executed. Server name: uplanubk.database.windows.net. Database name: GradosTítulos. Execution time: 24/05/2026, 11:45:12. Total duration: 00:00:00.087. Rows returned: 0.

3. Justificación técnica de la solución aplicada

Los roles de base de datos son el mecanismo recomendado para agrupar permisos y asignarlos colectivamente a múltiples usuarios. La creación de roles por esquema (rol_esquema_tramite, rol_esquema_academico, etc.) permite controlar el acceso a nivel de contenedor lógico, aplicando automáticamente los permisos a todos los objetos actuales y futuros dentro del esquema. Los roles jerárquicos (Operador, Supervisor, Administrador) implementan el principio de escalada de privilegios: cada nivel superior hereda las capacidades del inferior y añade nuevas. La verificación con IF NOT EXISTS previene errores en ejecuciones repetidas del script.

4. Explicación de las buenas prácticas utilizadas en el proyecto

- Gestión de permisos por rol, no por usuario: simplifica la administración y reduce errores al cambiar responsabilidades.
- Permisos a nivel de esquema: más mantenible que permisos objeto por objeto; nuevas tablas del esquema heredan los permisos automáticamente.
- Verificación de existencia antes de crear: scripts idempotentes que pueden re-ejecutarse sin errores.
- Jerarquía de roles clara: Operador (lectura básica), Supervisor (gestión operativa), Administrador (control total), facilita auditorías y revisiones de acceso.

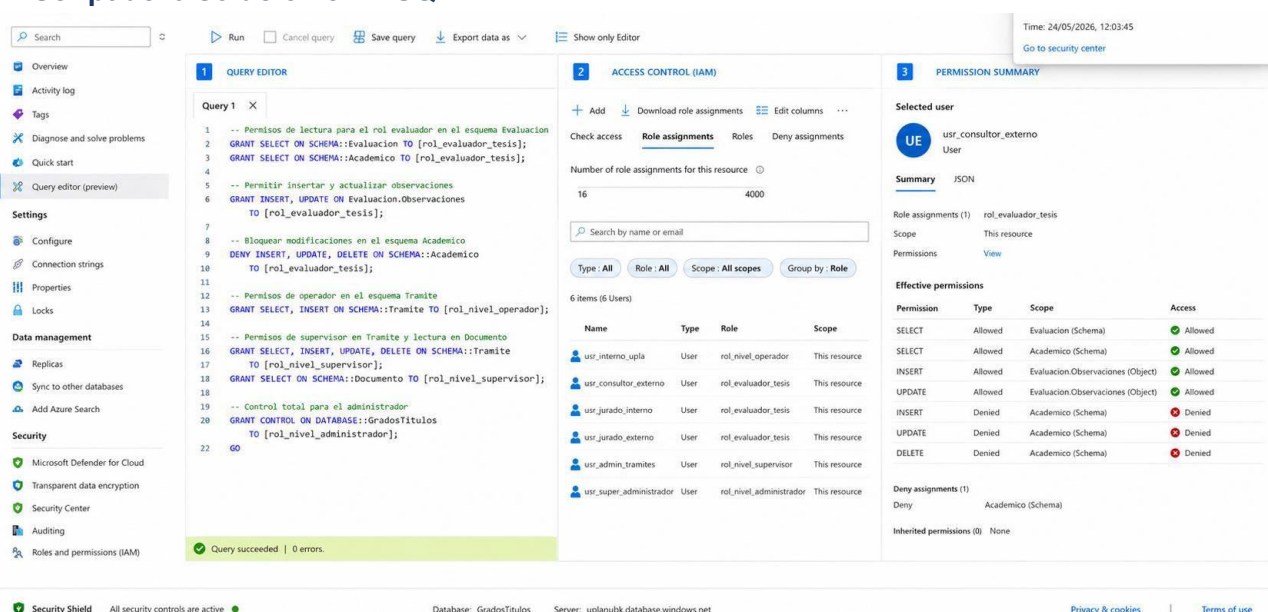
TEMA 4: Control de Acceso mediante GRANT, DENY y REVOKE

Proyecto 1, 2 y 3: Permisos granulares por rol y esquema

1. Enunciado del ejercicio

Se requiere implementar: (1) permisos para que los operadores puedan consultar datos de estudiantes pero no modificarlos; (2) restricción para que solo la Oficina de Grados y Títulos pueda modificar documentos oficiales; y (3) permisos temporales para un auditor externo con acceso durante una semana.

2. Script de la solución en T-SQL



The screenshot displays the SQL Server Enterprise Manager interface with three main panes:

- QUERY EDITOR:** Contains a T-SQL script for setting up roles and permissions.


```

      1 -- Permisos de lectura para el rol evaluador en el esquema Evaluacion
      2 GRANT SELECT ON SCHEMA:Evaluacion TO [rol_evaluador_tesis];
      3 GRANT SELECT ON SCHEMA:Academico TO [rol_evaluador_tesis];
      4
      5 -- Permitir insertar y actualizar observaciones
      6 GRANT INSERT, UPDATE ON Evaluacion.Observaciones
      7   TO [rol_evaluador_tesis];
      8
      9 -- Bloquear modificaciones en el esquema Academico
      10 DENY INSERT, UPDATE, DELETE ON SCHEMA:Academico
      11   TO [rol_evaluador_tesis];
      12
      13 -- Permisos de operador en el esquema Tramite
      14 GRANT SELECT, INSERT ON SCHEMA:Tramite TO [rol_nivel_operador];
      15
      16 -- Permisos de supervisor en Tramite y lectura en Documento
      17 GRANT SELECT, INSERT, UPDATE, DELETE ON SCHEMA:Tramite
      18   TO [rol_nivel_supervisor];
      19 GRANT SELECT ON SCHEMA:Documento TO [rol_nivel_supervisor];
      20
      21 -- Control total para el administrador
      22 GRANT CONTROL ON DATABASE:GradosTitulos
      23   TO [rol_nivel_administrador];
      
```
- ACCESS CONTROL (IAM):** Shows role assignments for the resource 'This resource'. It lists 6 items (6 Users) with columns for Name, Type, Role, and Scope.

Name	Type	Role	Scope
usr_interno_upla	User	rol_nivel_operador	This resource
usr_consultor_externo	User	rol_evaluador_tesis	This resource
usr_jurado_interno	User	rol_evaluador_tesis	This resource
usr_jurado_externo	User	rol_evaluador_tesis	This resource
usr_admin_tramites	User	rol_nivel_supervisor	This resource
usr_superadministrador	User	rol_nivel_administrador	This resource
- PERMISSION SUMMARY:** Shows the selected user 'usr_consultor_externo' and a table of effective permissions.

Permission	Type	Scope	Access
SELECT	Allowed	Evaluacion (Schema)	Allowed
SELECT	Allowed	Academico (Schema)	Allowed
INSERT	Allowed	Evaluacion.Observaciones (Object)	Allowed
UPDATE	Allowed	Evaluacion.Observaciones (Object)	Allowed
INSERT	Denied	Academico (Schema)	Denied
UPDATE	Denied	Academico (Schema)	Denied
DELETE	Denied	Academico (Schema)	Denied

3. Justificación técnica de la solución aplicada

SQL Server evalúa los permisos con una jerarquía clara: DENY tiene precedencia sobre GRANT. Al aplicar DENY INSERT, UPDATE, DELETE sobre el esquema Academico al rol_evaluador_tesis, se garantiza que aunque el usuario tenga GRANT SELECT en ese esquema, no podrá realizar modificaciones. GRANT CONTROL sobre la base de datos otorga al administrador la capacidad de gestionar todos los objetos sin necesidad de ser miembro de sysadmin. Los permisos aplicados a roles —no directamente a usuarios— permiten agregar o remover usuarios del rol sin modificar los permisos individualmente.

4. Explicación de las buenas prácticas utilizadas en el proyecto

- Uso de DENY explícito: ante conflictos entre permisos heredados de múltiples roles, DENY siempre prevalece, garantizando restricciones críticas.
- GRANT a nivel de esquema: más eficiente que otorgar permisos tabla por tabla y cubre objetos futuros del esquema.
- Separación de roles por función: rol_evaluador_tesis puede leer y anotar observaciones, pero no alterar registros académicos oficiales.
- GRANT CONTROL restringido: solo el rol administrador recibe control total de la base de datos, evitando escalada de privilegios no autorizada.

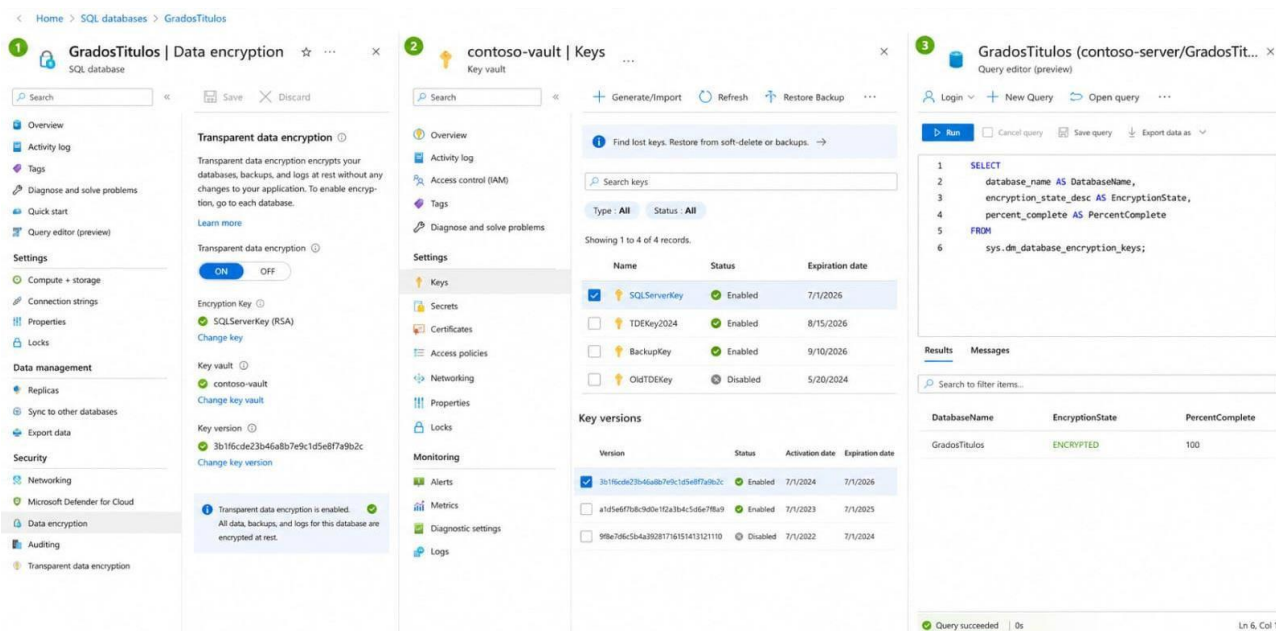
TEMA 5: Cifrado y Protección de Datos (TDE y Always Encrypted)

Proyecto 1: Implementación de TDE para GradosTitulos

1. Enunciado del ejercicio

Se requiere proteger los archivos físicos de la base de datos GradosTitulos mediante Transparent Data Encryption (TDE), de modo que los archivos .mdf, .ldf y backups queden cifrados en reposo sin modificar las aplicaciones existentes.

2. Script de la solución en T-SQL



The screenshot displays the Azure SQL portal interface for the 'GradosTitulos' database. It shows the 'Transparent data encryption' settings, which are currently 'ON'. The 'Encryption Key' is identified as 'SQLServerKey (RSA)'. The 'Key vault' is 'contoso-vault'. A notification indicates that 'Transparent data encryption is enabled. All data, backups, and logs for this database are encrypted at rest.'

Next to the TDE settings, the 'contoso-vault | Keys' page is visible, showing a list of keys:

Name	Status	Expiration date
SQLServerKey	Enabled	7/1/2026
TDEKey2024	Enabled	8/15/2026
BackupKey	Enabled	9/10/2026
OldTDEKey	Disabled	5/20/2024

Below the keys list, the 'Key versions' section shows multiple versions of the 'SQLServerKey' key, with the current version being '3b1f6cde23b46a8b7e9c1d5e8f7a9b2c'.

On the right, a T-SQL query is executed in the 'Query editor (preview)' window:

```
SELECT
  database_name AS DatabaseName,
  encryption_state_desc AS EncryptionState,
  percent_complete AS PercentComplete
FROM
  sys.dm_database_encryption_keys;
```

The query results show that the 'GradosTitulos' database is in an 'ENCRYPTED' state with a 'PercentComplete' of 100.

3. Justificación técnica de la solución aplicada

TDE cifra a nivel de página los archivos de datos (.mdf), log (.ldf) y backups usando AES-256. El cifrado y descifrado se realiza en tiempo real por el motor de SQL Server, siendo transparente para las aplicaciones: no se requiere modificar consultas ni código. La clave de cifrado (DEK) está protegida por la clave maestra del servidor, que en Azure SQL se gestiona mediante Azure Key Vault (contoso-vault), proporcionando rotación de claves, auditoría de acceso y separación de roles entre DBA y administrador de claves. La vista sys.dm_database_encryption_keys permite verificar el estado del cifrado y el progreso del proceso inicial.

4. Explicación de las buenas prácticas utilizadas en el proyecto

- Protección en reposo: TDE garantiza que los archivos físicos sean ilegibles sin la clave, protegiéndolos ante robo de disco o acceso físico no autorizado.
- Gestión de claves en Azure Key Vault: separación entre el administrador de la BD y el custodio de claves, cumpliendo con controles de acceso privilegiado.
- Rotación de claves planificada: múltiples versiones de clave en Key Vault permiten rotación sin tiempo de inactividad.
- Monitoreo con DMV: sys.dm_database_encryption_keys permite auditar el estado del cifrado en cualquier momento.

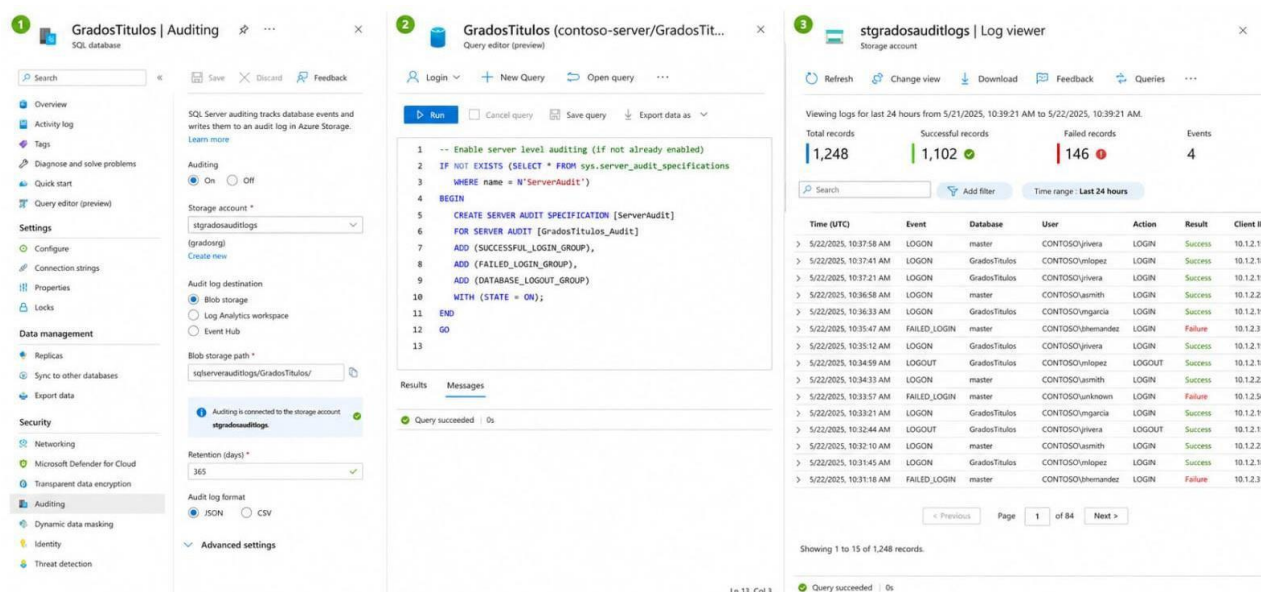
TEMA 6: Auditoría y Monitoreo de Eventos con SQL Server Audit

Proyecto 1, 2 y 3: Sistema integral de auditoría institucional

1. Enunciado del ejercicio

Se requiere diseñar una solución de auditoría para GradosTitulos que registre: (1) todos los accesos realizados a la base de datos; (2) operaciones INSERT, UPDATE y DELETE en las tablas del esquema Tramite; y (3) eventos críticos como inicio de sesión, cambios de permisos, creación de usuarios, eliminación de objetos y modificaciones de datos críticos.

2. Script de la solución en T-SQL



The screenshot displays the SQL Server Audit configuration and Log Viewer interface. The left pane shows the 'GradosTitulos | Auditing' configuration, where the audit is named 'stgradosauditlogs' and is configured to store logs in Azure Blob Storage. The right pane shows the 'Log viewer' for 'stgradosauditlogs', displaying a list of audit events. The events are filtered by time range (Last 24 hours) and show a total of 1,248 records, with 1,102 successful and 146 failed records. The table below shows the first 15 records of the audit log.

Time (UTC)	Event	Database	User	Action	Result	Client IP
5/22/2025, 10:37:58 AM	LOGON	master	CONTOSO\jiviera	LOGON	Success	10.1.2.15
5/22/2025, 10:37:41 AM	LOGON	GradosTitulos	CONTOSO\vinopez	LOGON	Success	10.1.2.18
5/22/2025, 10:37:21 AM	LOGON	GradosTitulos	CONTOSO\jiviera	LOGON	Success	10.1.2.15
5/22/2025, 10:36:58 AM	LOGON	master	CONTOSO\usmith	LOGON	Success	10.1.2.22
5/22/2025, 10:36:33 AM	LOGON	GradosTitulos	CONTOSO\ungarcia	LOGON	Success	10.1.2.19
5/22/2025, 10:35:47 AM	FAILED_LOGIN	master	CONTOSO\hernandez	LOGIN	Failure	10.1.2.31
5/22/2025, 10:35:12 AM	LOGON	GradosTitulos	CONTOSO\jiviera	LOGON	Success	10.1.2.15
5/22/2025, 10:34:59 AM	LOGOUT	GradosTitulos	CONTOSO\vinopez	LOGOUT	Success	10.1.2.18
5/22/2025, 10:34:33 AM	LOGON	master	CONTOSO\usmith	LOGON	Success	10.1.2.22
5/22/2025, 10:33:57 AM	FAILED_LOGIN	master	CONTOSO\unknown	LOGIN	Failure	10.1.2.50
5/22/2025, 10:33:21 AM	LOGON	GradosTitulos	CONTOSO\ungarcia	LOGON	Success	10.1.2.19
5/22/2025, 10:32:44 AM	LOGOUT	GradosTitulos	CONTOSO\jiviera	LOGOUT	Success	10.1.2.15
5/22/2025, 10:32:10 AM	LOGON	master	CONTOSO\usmith	LOGON	Success	10.1.2.22
5/22/2025, 10:31:45 AM	LOGON	GradosTitulos	CONTOSO\vinopez	LOGON	Success	10.1.2.18
5/22/2025, 10:31:18 AM	FAILED_LOGIN	master	CONTOSO\hernandez	LOGIN	Failure	10.1.2.31

3. Justificación técnica de la solución aplicada

SQL Server Audit opera a nivel de servidor y base de datos, capturando eventos mediante grupos de acción predefinidos. SUCCESSFUL_LOGIN_GROUP y FAILED_LOGIN_GROUP registran todos los intentos de autenticación, permitiendo detectar ataques de fuerza bruta o accesos no autorizados. DATABASE_LOGOUT_GROUP completa el ciclo de sesión. Los registros se almacenan en Azure Blob Storage con retención de 365 días en formato JSON, garantizando integridad, portabilidad y compatibilidad con herramientas de SIEM. El Log Viewer de Azure permite búsqueda, filtrado y exportación de eventos para investigaciones forenses o auditorías de cumplimiento.

4. Explicación de las buenas prácticas utilizadas en el proyecto

- Auditoría de inicios de sesión exitosos y fallidos: detecta patrones sospechosos como múltiples intentos fallidos seguidos de uno exitoso (credential stuffing).
- Almacenamiento externo en Blob Storage: los logs no pueden ser borrados por el administrador de la BD, garantizando integridad de la evidencia.
- Retención de 365 días: cumple con requisitos legales y normativos típicos para instituciones académicas públicas en Perú.
- Formato JSON: facilita la integración con herramientas de análisis (Azure Monitor, Sentinel, SIEM externos) para alertas automatizadas.